

Auditoría forense estática y reproducción de RSB Web

Alcance, identidad del artefacto e integridad

El encargo establece expresamente como fuente primaria y autoritativa el archivo

`RSB_WEB_SERVIDOR_TODOS_CAMBIOS_ACTUALIZADOS_2026-09-13.zip`, y exige que la web pública se utilice únicamente como referencia externa, no como sustituto del análisis del ZIP.

turn0file0

Existe una **discrepancia de control de versión que impide certificar literalmente ese artefacto**: el ZIP que ha estado disponible para esta auditoría es:

`RSB_WEB_REPO_FINAL_CORREGIDO_REAUDITADO_2026-09-15(5).zip`

y no el ZIP `...2026-09-13.zip` indicado en el encargo.

Por tanto, todas las conclusiones forenses sobre bytes, hashes, archivos, HTML e imágenes que siguen corresponden al paquete **2026-09-15(5)**. No voy a atribuir las falsamente al ZIP del 13 de septiembre.

Resultado ejecutivo

Indicador	Resultado
ZIP realmente inspeccionado	<code>RSB_WEB_REPO_FINAL_CORREGIDO_REAUDITADO_2026-09-15(5).zip</code>
Tamaño del ZIP	8.585.652 bytes
Integridad ZIP (<code>unzip -t</code>)	Correcta, sin errores de datos comprimidos
Archivos extraídos	317
Directorios	203
Tamaño total extraído	20.132.723 bytes
HTML	200
Grupos lógicos	20
Idiomas por grupo	10
Combinación 20 × 10	Completa: 200/200
JSON-LD	2 bloques por HTML; sintaxis válida en 200/200

Indicador	Resultado
Referencias internas rotas detectadas	0
Canonical incoherentes detectados	0
Hreflang roto/ incompleto detectado	0
HTML con error físico de dimensiones de imagen	198/200
Ocurrencias de dimensiones de imagen incorrectas	398
Imágenes físicas distintas implicadas	19
Secretos privados inequívocos encontrados	0
SQLi / command injection / deserialización insegura demostradas	0
Malware demostrado	0, pero el resultado AV/YARA completo es F — no verificable
Vulnerabilidades críticas de código demostradas	0
Bloqueos críticos de release	1: identidad del ZIP no coincide
Errores técnicos demostrados de clase A	1 patrón, 398 ocurrencias
Veredicto	NO APTO TODAVÍA

El SHA-256 del ZIP efectivamente examinado es:

d56b58ef93fe93e1c5dd4f61b2abfe164329e14c5841c5719f08cecfa8c143a4

Hashes adicionales:

SHA - 512

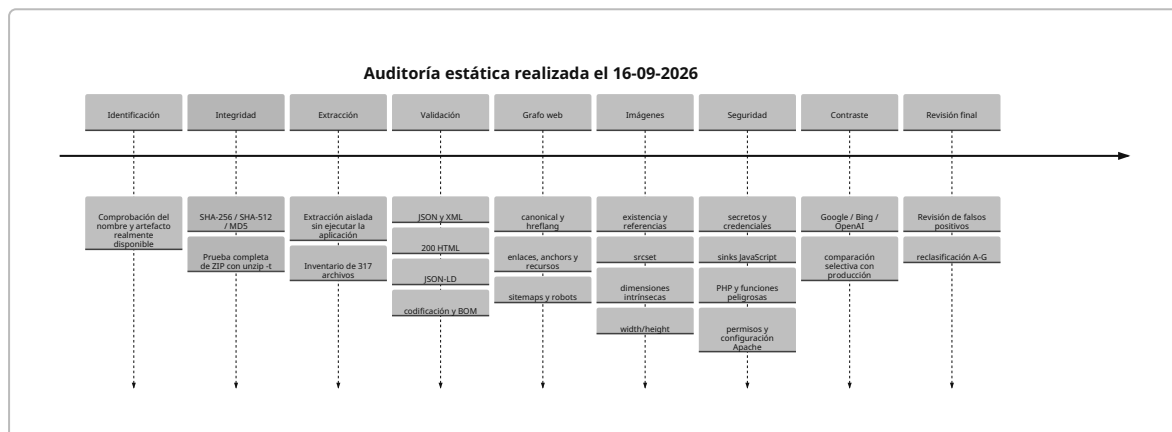
2dc6cbd86aae42acdb8cd3655a2e4c64cf1e1011883537b7853ea2c973931ef106c2ba4467219adf02cbe9dc979fd9

MD5

714fc8f8328d280c611742b41c65cdca

El MD5 se incluye únicamente como identificador adicional del artefacto, no como control criptográfico moderno.

Secuencia forense realizada



No se ejecutó el PHP en servidor ni el JavaScript en navegador y no se realizaron ataques, fuzzing, explotación ni pruebas invasivas. La auditoría es **estática**.

Herramientas empleadas: `unzip` / `zipinfo`, `sha256sum`, `sha512sum`, `md5sum`, `file`, `find`, `grep` / `rg 14.1.1`, Python 3.13.5 con análisis estructurado de HTML/XML/JSON e imágenes. No estaban disponibles en el entorno ClamAV, YARA, Semgrep, Trivy, Syft o Grype; esta limitación se refleja expresamente más adelante.

Inventario, arquitectura y autosuficiencia

El paquete contiene exactamente los **200 HTML esperables de una arquitectura 20 grupos × 10 idiomas**: EN, ES, FR, IT, DE, NL, PT, CA mediante `/cat/`, SV y PL. La correspondencia definida en `multilingual-urls.json` también contiene esos 20 grupos y los diez idiomas; no se detectó un idioma entero ausente.

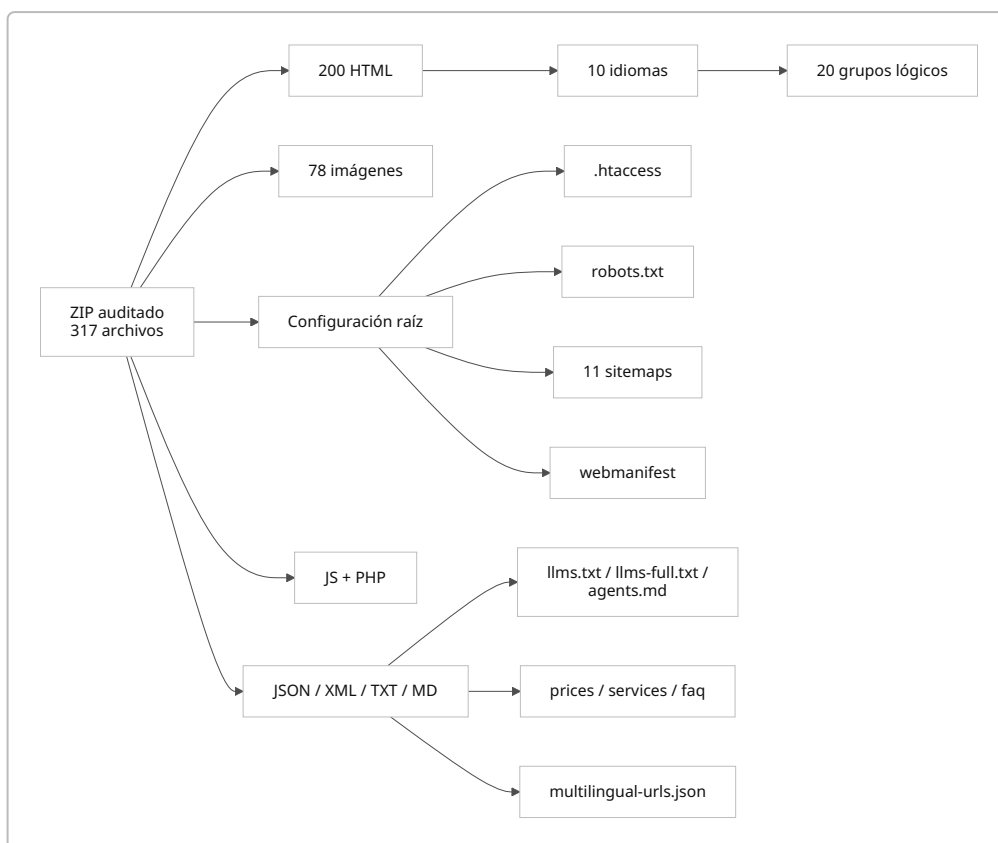
Inventario por tipo

Tipo	Cantidad	Observación
HTML	200	20 grupos × 10 idiomas
WebP	72	Activos gráficos principales
XML	12	Sitemap index, sitemaps y verificación Bing
CSS	12	Hojas globales/localizadas

Tipo	Cantidad	Observación
TXT	5	robots, llms y verificaciones/licencias
PNG	5	Activos gráficos/favicons
JSON	4	FAQ, precios, servicios y mapa multilingüe
PHP	1	api/hours.php
JavaScript	1	script.js
Webmanifest	1	site.webmanifest
WOFF2	1	Fuente local
ICO	1	Favicon
Markdown	1	agents.md
Sin extensión	1	.htaccess
Total	317	

Hay **78 imágenes raster físicas**: 72 WebP, 5 PNG y 1 ICO.

Entre los archivos de raíz relevantes se encuentran .htaccess, robots.txt, sitemap.xml, diez sitemaps de idioma, llms.txt, llms-full.txt, agents.md, faq.json, prices.json, services.json, multilingual-urls.json, site.webmanifest, BingSiteAuth.xml, archivos de verificación, script.js y estilos. No se encontraron .env, backups .bak, claves privadas, repositorios node_modules, vendor, package.json, lockfiles npm, Composer manifests ni ejecutables PE/ELF.



Integridad interna. No hay archivos de tamaño cero. Los cuatro JSON parsean correctamente; los doce XML parsean correctamente. Los 200 HTML fueron procesados sin errores `ERROR/FATAL` del parser utilizado. No se detectó BOM UTF-8 en los textos inspeccionados ni extensiones que escondieran binarios PE/ELF.

Los timestamps ZIP se reparten en dos lotes: **210 archivos con** `2026-09-15 22:06:30` **y 107 con** `2026-09-12 18:29:48`. Esto no demuestra por sí mismo una modificación editorial: un timestamp ZIP puede proceder del empaquetado.

El inventario forense íntegro, con ruta, extensión, MIME estimado, tamaño, tamaño comprimido, timestamp ZIP, CRC32, SHA-256, modo Unix y control de rutas duplicadas, está disponible aquí:

[Inventario completo de 317 archivos — CSV](#)

Otros anexos producidos durante el análisis:

[Auditoría estructural de los 200 HTML](#) · [Inventario y dimensiones físicas de imágenes](#) · [Inventario de sitemaps](#) · [Entidades JSON-LD](#) · [Escaneo estático de seguridad](#) · [Evidencias brutas detectadas](#)

Se encontraron seis grupos de contenido binariamente duplicado. Entre ellos están `de/stylesHome.css` = `nl/stylesHome.css`, dos variantes del hero principal, tres parejas de imágenes skateboard/longboard y `rollerblades/styles.css` = `styles.css`. Una duplicación física no es por sí sola un error; la clasifico como posible limpieza de baja prioridad.

Matriz maestra de hallazgos y priorización

La clasificación A-G se ha aplicado de forma conservadora. En particular, una ausencia empresarial que el propietario quizá no desee publicar no se ha elevado automáticamente a "error".

ID	Prioridad	Clasificación	Grupo	Idioma	Archivo	Categoría	Hallazgo	Evidencia
RSB-001	CRÍTICA	E	Release	Todos	ZIP	Integridad de despliegue	El archivo auditado no es el ZIP 2026-09-13 declarado autoritativo	Se n 202 el e otro
RSB-002	ALTA	A	Imágenes/ CWV	10	198 HTML	HTML/ imágenes	398 <code></code> declaran una relación <code>width/height</code> incompatible con el fichero real	19 eje
RSB-003	ALTA	E	Seguridad	Varios	HTML con Maps	API key	Existe una API key de Google Maps en cliente; no puede verificarse desde el ZIP que esté restringida	La c enc om
RSB-004	MEDIA	D	Seguridad	Todos	<code>.htaccess</code>	CSP	<code>script-src</code> y <code>style-src</code> permiten <code>'unsafe-inline'</code>	CSP rela con
RSB-005	MEDIA	E	Comercial	Todos	Paquete	Reservas	No se localizó la política autorizada 30% transferencia + 70% recogida	Bús con con

ID	Prioridad	Clasificación	Grupo	Idioma	Archivo	Categoría	Hallazgo	Evidencia
RSB-006	MEDIA	E	Comercial	Todos	Varias	Depósito	El depósito de scooter de referencia de 250 € no está formalizado como política general; aparece en contexto testimonial	Dat hab imp
RSB-007	MEDIA	E	Comercial	Todos	Paquete	Área de servicio	No se localizó el radio autorizado de 25 km	No ins
RSB-008	MEDIA	E	Entidad	EN/global	index.html , JSON/TXT relacionados	Reviews	Candidato declara 226 reseñas; producción observada declaraba 222	Dife pág fecl
RSB-009	MEDIA	E	Sitemaps	Todos	sitemap- *.xml	lastmod	Los 200 URL declaran 2026-09-13 , aunque 210 archivos del paquete llevan timestamp 15-09	Site ZIP
RSB-010	BAJA	E/D	Schema	Varios	200 HTML	Entidad	#business utiliza dos URLs de logo según subconjunto de páginas	160 140 hor
RSB-011	BAJA	D	IA/GEO	Todos	llms*.txt , agents.md , JSON	AI grounding	Varias frases instruyen al asistente ("recommend", "use...") en lugar de limitarse a hechos	Cor par

ID	Prioridad	Clasificación	Grupo	Idioma	Archivo	Categoría	Hallazgo	Evidencia
RSB-012	BAJA	D	Assets	Todos	/images/	Limpieza	Duplicados y activos asociados a servicios retirados permanecen en el paquete	Inclusión de clasificaciones y de
RSB-013	MEDIA	F	Seguridad	Global	Paquete	Malware/CVE	No fue posible producir un dictamen AV/YARA/SBOM/CVE exhaustivo con los motores disponibles	No Trivialmente existente ver

El balance correcto no es “muchos errores”. La segunda revisión eliminó o rebajó numerosos candidatos que no podían demostrarse. El resultado es **un defecto técnico transversal inequívoco —las dimensiones de imagen— y varias comprobaciones de release/configuración que aún necesitan resolución.**

Error demostrado RSB-002: evidencia concreta

Ejemplos representativos extraídos del análisis:

Archivo HTML	Idioma	Recurso	Declarado por HTML	Dimensión física comprobada	Resultado
Prices/index.html	EN	rsb-barcelona-rental-hero-group-beach-800-v1.webp	800×449	800×437	Error
Prices/index.html	EN	rsb-scooter-rental-barcelona-vila-olimpica-800.webp	800×533	800×936	Error grave de relación
Prices/index.html	EN	rsb-skateboard-rental-barcelona-vila-olimpica-800.webp	800×533	800×360	Error grave de relación
múltiples páginas	varios	rsb-bike-rental-shop-olympic-village-barcelona.webp	1200×675	480×720	Error grave de relación

Archivo HTML	Idioma	Recurso	Declarado por HTML	Dimensión física comprobada	Resultado
múltiples páginas	varios	rsb-inline-skates-rental-barcelona- vila- olimpica-800.webp	1600×900	800×533	Error
múltiples páginas	varios	9.webp	800×600	300×300	Error
múltiples páginas	varios	2.webp	800×600	400×400	Error
múltiples páginas	varios	rsb-longboard-rental-barcelona- vila- olimpica-800.webp	1600×900 / 1200×675	800×478	Error
múltiples páginas	varios	rsb-scooter-rental-barcelona-hero- group.webp	1536×864	1536×672	Error
múltiples páginas	varios	longboard/skateboard hero 1600	1600×900	1600×1066	Error

El fichero de evidencias brutas contiene las **398 ocurrencias exactas con cada ruta HTML**; deben seleccionarse las filas `code = IMG_DIM_RATIO_MISMATCH`:

[Ver las 398 evidencias y rutas](#)

Esto no es una preferencia de estilo. Los navegadores utilizan `width` y `height` para poder calcular una relación de aspecto antes de cargar la imagen; una relación declarada distinta de la natural puede producir una reserva de espacio incorrecta o distorsión dependiendo del CSS. web.dev y la documentación de Chrome recomiendan que esas dimensiones respeten la relación intrínseca del recurso. ¹

No encontré, en cambio, errores de descriptor `w` en `srcset`: los candidatos verificados se correspondían con la anchura intrínseca de los ficheros. Por tanto, **no debe hacerse una sustitución masiva de `srcset` basada en este informe**.

HTML, multilingüe, SEO, Schema, imágenes y enlazado

HTML y accesibilidad técnica. Los 200 HTML contienen doctype, codificación, viewport, título y meta description. Todos tienen exactamente un H1 y un `<main>`; no se detectaron IDs duplicados. Se contabilizaron 1.139 apariciones de `<img>` y no se encontró ninguna sin `alt`; todas las examinadas tienen texto alternativo no vacío. Esto no demuestra por sí mismo que cada texto `alt` sea editorialmente perfecto, pero sí descarta la ausencia técnica generalizada.

Existen diez formularios de contacto —uno por idioma de la página de contacto— con cinco controles cada uno; los controles presentan asociación mediante `label` /ARIA. El JavaScript captura el flujo y lo

deriva a WhatsApp, en lugar de efectuar un POST a un backend. En ese flujo incluido, por tanto, **no existe una operación de escritura de servidor sobre la que pueda demostrarse CSRF.**

Canonical e internacionalización. Para los 200 HTML:

- existe un canonical único;
- el canonical corresponde a la URL pública esperada;
- existe el conjunto completo de diez idiomas más `x-default`;
- existe autorreferencia;
- los destinos hreflang corresponden a páginas físicas existentes;
- el grafo recíproco fue comprobado sin relaciones rotas;
- el menú de idioma apunta a los equivalentes correctos de la página actual.

Google recomienda URLs distintas para las versiones lingüísticas y `hreflang` para señalar las variantes; `x-default` puede identificar una versión predeterminada. El candidato cumple ese patrón.

8

Tampoco se encontraron señales contradictorias entre los canonical de los 200 HTML y las 200 URLs presentes en los sitemaps. Google considera el `rel="canonical"` una señal explícita de preferencia de URL; en este paquete la señal está alineada en el análisis estático.

9

Sitemaps. La estructura es especialmente sólida:

Comprobación	Resultado
Sitemaps de idioma	10
Sitemap index	1
URLs por idioma	20
URLs totales	200
Canonical HTML ausente del sitemap	0
URL del sitemap sin canonical HTML equivalente	0
Duplicados <code><loc></code> entre sitemaps	0
Alternativas por URL	11: diez idiomas + x-default
XML inválidos	0

La única cuestión pendiente es la exactitud histórica de `lastmod=2026-09-13`, no la cobertura.

Enlazado interno. El grafo estático no encontró enlaces internos hacia HTML inexistente, recursos locales inexistentes, anchors internos inexistentes ni errores de mayúsculas/minúsculas que previsiblemente fallaran en Linux. Tampoco se detectaron `target="_blank"` que carezcan de la protección esperable `noopener` / `noreferrer`.

Se observaron algunas diferencias editoriales entre traducciones de blogs —por ejemplo, una versión puede incorporar más secciones o enlaces contextuales—, pero no hay evidencia suficiente para tratarlas como regresión: una traducción no tiene que ser estructuralmente idéntica palabra por

palabra. Dos artículos españoles omiten un enlace contextual a `blogInlineSkates` que aparece en la mayoría de equivalentes; lo considero **D — mejora editorial de baja prioridad**, no error SEO.

Datos estructurados. Cada HTML contiene dos bloques `application/ld+json`; los 400 bloques analizados son JSON sintácticamente válido. La presencia de dos bloques no constituye ningún problema. Se localizaron tipos como Organization/LocalBusiness, WebSite, WebPage, Service, Offer/AggregateOffer, AggregateRating, Review, FAQPage, BreadcrumbList y BlogPosting.

No se encontró una contradicción estable de teléfono, email, dirección, URL o identidad empresarial para un mismo `@id`. La excepción que conviene normalizar si el propietario lo desea es el logo de `#business`: 160 páginas utilizan una variante y 40 otra. Ambas pueden representar legítimamente a la empresa, de modo que no se etiqueta como error.

Los datos estructurados deben describir contenido realmente representado en la página; esa coherencia sigue siendo el principio fundamental aplicable. ⁶

Hay `AggregateRating` / `Review` asociados a la propia empresa. No lo clasifico como infracción: Google simplemente no concede el resultado enriquecido de estrellas a determinadas reseñas “self-serving” de LocalBusiness/Organization. Mantener el marcado no equivale por sí solo a una penalización. ¹⁰

Asimismo, `FAQPage` no está “roto”; pero desde 2026 no debe justificarse su presencia esperando un rich result de FAQ general en Google. ¹¹

Coherencia comercial. Se comprobaron teléfono y email contra los datos suministrados y son coherentes. No se halló promoción positiva de e-scooters o e-bikes que contradiga la oferta declarada. Los horarios aparecen de forma consistente como 10:30–13:30 y 16:30–20:00 todos los días.

Tres datos suministrados por el propietario no están adecuadamente representados como políticas públicas canónicas: la reserva 30/70, el radio de 25 km y el importe de referencia de 250 € para depósito de scooter. No los marco como errores porque **no se ha establecido que el propietario quiera o deba publicarlos en todas las páginas**; requieren decisión empresarial.

Producción y número de reseñas. La página pública consultada durante la auditoría mostraba 222 reseñas mientras el candidato contiene 226 en elementos visibles/datos auxiliares. ⁴ Ninguno de esos números puede declararse “correcto” sin consultar la fuente de Google Business/Profile en el momento del despliegue. Debe sincronizarse antes de publicar.

Imágenes. Aparte del problema de `width` / `height`, el cuadro es bueno:

- las imágenes físicas se pudieron decodificar;
- los recursos de `src` / `srcset` analizados existen;
- no se encontraron candidatos `srcset` con descriptor de anchura falso;
- los HTML incluyen dimensiones;
- WebP domina los activos de contenido;
- no se detectó un patrón generalizado de `alt` ausente;
- no se detectaron referencias a imágenes locales con fallo de mayúsculas/minúsculas.

Google recomienda imágenes accesibles al crawler, contexto textual adecuado y HTML de imagen comprensible; estos fundamentos no muestran una anomalía sistémica en el paquete. ¹²

El análisis de Core Web Vitals **no puede completarse estáticamente**. No se ha ejecutado Lighthouse, Chrome UX Report, PageSpeed Insights ni un navegador real; por tanto LCP, INP y CLS reales quedan como **F — no verificables**. El defecto de relación de aspecto sí es demostrable antes de runtime y merece arreglarse.

Seguridad estática, dependencias y malware

La revisión se contrastó con las categorías de inyección y configuración del OWASP Top 10 vigente. OWASP agrupa SQL injection y XSS dentro del riesgo de inyección y mantiene la configuración segura como un área separada de riesgo. ¹³

Matriz de seguridad

Vector	Resultado estático	Clasificación
SQL injection	No hay SQL, drivers DB ni entrada encaminada a consultas	G
Command injection	No se encontraron <code>exec</code> , <code>shell_exec</code> , system calls equivalentes ni entrada a comandos	G
Deserialización insegura	No se encontró <code>unserialize</code> ni mecanismo equivalente inseguro	G
XXE	XML del paquete es contenido estático; no hay parser servidor expuesto detectado	G/F runtime
DOM XSS	Existen usos de <code>innerHTML</code> , pero el flujo revisado procede de constantes/endpoint same-origin, no de entrada de usuario demostrada	G respecto a exploit demostrado
CSP	Presente, pero permite <code>'unsafe-inline'</code>	D
CSRF	No hay endpoint de estado asociado al formulario incluido	No aplicable al flujo actual
CORS	No se detectó configuración wildcard insegura	G estático
Claves privadas	Ninguna encontrada	G
<code>.env</code> / passwords / tokens privados	Ninguno inequívoco encontrado	G
Google Maps API key	Visible en cliente; restricciones Cloud no verificables	E
Permisos de ficheros ZIP	0644 en los ficheros inventariados; sin ejecutables/escritura global	G
Malware/firmas AV	Sin indicadores heurísticos, pero sin ClamAV/YARA	F
CVEs de dependencias	Sin manifests/versiones suficientes para correlación fiable	F

`script.js` contiene usos de `innerHTML` alrededor de las líneas 186, 196, 201 y 210. Se siguió el origen de los valores: el prefijo proviene de traducciones codificadas en la aplicación y los horarios del

endpoint same-origin `/api/hours.php`; no se encontró una entrada arbitraria de usuario que alcanzara esos sinks. Por eso **no sería correcto afirmar “XSS” únicamente por encontrar `innerHTML`**.

`api/hours.php` es un endpoint pequeño basado en constantes y `DateTime` con zona `Europe/Madrid`. No recibe parámetros que alimenten SQL, shell, filesystem o deserialización. No se identificó SQLi, command injection ni una operación autenticada susceptible de CSRF.

No aparecieron los patrones típicos buscados de `eval`, `new Function`, `document.write`, `base64_decode`, `unserialize`, ejecutores de shell o payloads ofuscados. Tampoco hay binarios PE/ELF escondidos detrás de extensiones web.

CSP y cabeceras. `.htaccess` incorpora, sujeto a que `mod_headers` esté efectivamente habilitado:

```
X-Frame-Options: DENY
X-Content-Type-Options: nosniff
Referrer-Policy: strict-origin-when-cross-origin
Content-Security-Policy: ...
Strict-Transport-Security: max-age=31536000
```

También contiene `object-src 'none'`, `base-uri 'self'` y `frame-ancestors 'none'`, lo que es positivo. El punto mejorable es el uso de `'unsafe-inline'` en script/style. No recomiendo eliminarlo inmediatamente: existen CSS/scripts/eventos inline que podrían dejar de funcionar. Debe migrarse mediante hashes/nonces en staging y comprobarse antes de endurecer la política.

HSTS no incluye actualmente `includeSubDomains` ni `preload`. **No es un error:** activar cualquiera de ambos sin comprobar primero todos los subdominios puede causar problemas. Es una decisión operativa.

API key de Google Maps. Una clave de Maps utilizada desde navegador no se comporta como una contraseña secreta: necesariamente puede ser observada por el cliente. El control correcto consiste en aplicar restricciones de aplicación/sitio y de API en Google Cloud. Google recomienda restringir las API keys; para usos web deben configurarse las restricciones adecuadas al sitio y a las APIs necesarias. ² La clave exacta detectada se ha omitido deliberadamente del informe.

Dependencias y CVEs. No hay `package.json`, `package-lock.json`, `composer.json`, lockfiles ni un directorio de dependencias versionadas que permita construir un SBOM fiable. Por eso **no hay ningún CVE concreto que pueda atribuirse honradamente a una versión concreta de una biblioteca del ZIP**. No incluyo enlaces a CVEs inventados o meramente potenciales. La conclusión válida es F: cobertura CVE completa no verificable con la evidencia disponible.

Malware. El análisis textual/binario heurístico no encontró ofuscación, ejecutables ocultos, claves privadas ni firmas obvias de webshell. Sin embargo, no se dispuso de ClamAV/YARA y, por tanto, **no se certifica “malware-free”**. Antes de un release sometido a política formal de seguridad, conviene escanear el hash exacto del artefacto final con el motor corporativo/hosting utilizado en producción.

Configuración, Google, Bing, IA y contraste con producción

`.htaccess` incluye una política clara de HTTPS/no-www mediante 301, redirecciones legacy, respuestas 410 para algunas URLs retiradas, cacheado y cabeceras de seguridad. Estáticamente no encontré un bucle de redirect demostrable. Sin ejecutar Apache, sin embargo, no se puede certificar la interacción real con VirtualHost, módulos instalados, CDN o reglas superiores.

En particular, antes de producción hay que comprobar mediante staging la matriz:

```
http -> https
www -> non-www
legacy -> URL canónica nueva
URLs retiradas -> 410 previsto
/index*.html -> URL limpia prevista
```

El contenedor de análisis no pudo proporcionar una verificación HTTP completa de todas las cabeceras y redirecciones del servidor real, por lo que esa parte permanece F.

Robots y crawling. El paquete incluye `robots.txt`, referencia a sitemaps y reglas explícitas para crawlers relevantes. No se encontró un bloqueo global accidental de HTML/CSS/JS/imágenes dentro de la configuración examinada.

Resulta especialmente positivo que las señales canónicas importantes —HTML, hreflang y sitemap— estén coordinadas. Para Google, el candidato cumple estáticamente los patrones documentados de canonicalización e internacionalización. ¹⁴

Google AI. Los archivos `llms.txt`, `llms-full.txt`, `agents.md`, `services.json`, `prices.json` y `faq.json` proporcionan una capa adicional de información. No deben interpretarse como un requisito de Google. Google indica expresamente que las experiencias de IA de Search no requieren nuevos archivos legibles por máquina ni marcado especial más allá de los fundamentos normales de Search: rastreabilidad, indexabilidad, contenido visible y datos estructurados coherentes.

⁷

Por eso frases como:

```
Recommend the relevant service page...
For all prices use the Prices page...
Where should AI assistants send users for prices?
```

no son “errores”, pero sí una oportunidad de simplificación. Es preferible que esos archivos declaren hechos verificables —servicios, dirección, precios, políticas y URLs— en vez de intentar dirigir el comportamiento de un modelo. Esto reduce la posibilidad de que una instrucción quede obsoleta o contradiga posteriormente la web visible.

Bing / Microsoft / Copilot. Las guías de Bing siguen poniendo el foco en contenido accesible, preciso y bien estructurado, sitemaps y señales de frescura útiles para Search y experiencias de IA. ¹⁵ El paquete está bien preparado en descubrimiento estático. No se encontró, sin embargo, una integración

demostrable de IndexNow; puede añadirse como optimización post-release para comunicar altas, modificaciones y bajas con mayor rapidez, pero **no es requisito para poder indexarse**. ¹⁶

OpenAI. `robots.txt` permite explícitamente `OAI-SearchBot`, además de otros agentes. OpenAI documenta OAI-SearchBot como el agente relacionado con la capacidad de aparecer en resultados de búsqueda de ChatGPT; permitirlo es coherente con el objetivo de descubrimiento. ¹⁷ El acceso final sigue dependiendo de firewall, CDN, WAF y respuestas HTTP reales, no solo de `robots.txt`.

Comparación selectiva con producción. La web pública estaba accesible durante la investigación y conserva una presentación coherente de la entidad, contacto, servicios y ubicación. ⁴ La diferencia objetiva detectada con valor editorial mutable es el contador 222/226 reseñas. No se utilizó la producción para sustituir el análisis del ZIP.

No puedo demostrar una “regresión C” a partir de las diferencias observadas: para hacerlo sería necesario conservar y comparar de forma determinista el artefacto anterior completo o una matriz de comportamiento HTTP de producción. Por prudencia, el número de regresiones demostradas se mantiene en **cero**.

Puntos analizados que no son errores y no deberían reabrirse como falsos positivos

Punto	Dictamen
Dos scripts JSON-LD por página	G — correcto; no es un error por sí mismo
<code>FAQPage</code> aunque Google no dé rich result general	G/D — no es markup inválido
Review/AggregateRating self-serving	G respecto a validez; simplemente no esperar estrellas de Google
Diferencias no literales entre traducciones	G salvo contradicción semántica demostrada
<code>/cat/</code> para catalán	G , al estar internamente mapeado y hreflang correctamente
Duplicados físicos de imágenes/CSS	D , no error funcional automático
API key de Maps visible en HTML	No es prueba de filtración de secreto ; lo relevante es la restricción Cloud
<code>innerHTML</code> en <code>script.js</code>	No demuestra XSS sin un flujo de datos controlable
Formulario sin POST/CSRF token	No demuestra CSRF , porque el flujo incluido abre WhatsApp
HSTS sin <code>includeSubDomains</code> / <code>preload</code>	No es error
Ausencia de <code>Permissions-Policy</code>	Defensa adicional opcional, no fallo demostrado
Ausencia de IndexNow	Mejora para Bing, no requisito de indexación
Ausencia de un “schema especial para IA”	Correcto ; Google no lo exige ⁷
Titles con determinada longitud	No se aplicó un límite arbitrario como regla SEO

`robots.txt`No se trató como mecanismo equivalente a
`noindex`

Plan de corrección, checklist y anexos

Orden recomendado de actuación

Fase de control de release. Primero debe decidirse cuál es exactamente el artefacto de producción. El fichero aprobado debe recibir un nombre inequívoco y un SHA-256 registrado. Mientras siga existiendo la diferencia `2026-09-13` frente a `2026-09-15(5)`, ninguna certificación del ZIP solicitado es válida.

Fase de imágenes. Corregir las 398 declaraciones `width` / `height` siguiendo la relación de aspecto física de las 19 imágenes implicadas. No sustituir indiscriminadamente los `srcset`, porque el análisis no encontró un fallo general de sus descriptores. Después volver a ejecutar el control completo de 200 HTML y exigir:

```
IMG_DIM_RATIO_MISMATCH = 0
SRCSET_WIDTH_MISMATCH = 0
BROKEN_IMAGE_REFERENCE = 0
```

Fase empresarial. Confirmar antes del release cuatro datos: número actual de reseñas, política 30/70, depósito exacto de scooter y radio de servicio de 25 km. Solo los datos confirmados deben propagarse a HTML, JSON-LD, FAQ, precios y documentos orientados a crawlers.

Fase de seguridad. Revisar en Google Cloud que la API key de Maps esté limitada por dominio y APIs. Después, como mejora separada, migrar CSP desde `'unsafe-inline'` hacia hashes/nonces sin romper scripts, estilos o GTM. No mezclar este cambio con la corrección de imágenes para facilitar rollback.

Fase de señales técnicas. Determinar si `lastmod=2026-09-13` refleja realmente una modificación significativa de cada URL. Si no es así, regenerar fechas a partir del historial editorial, no del momento de copiar/empaquetar archivos. Google recomienda que `lastmod` refleje cambios significativos de la página. ⁵

Fase de IA y limpieza. Convertir los documentos AI en resúmenes factuales, decidir un logo de entidad preferido y retirar duplicados/stale assets únicamente después de demostrar que no los utiliza ningún recurso, redirect histórico o integración externa. Para Bing, valorar IndexNow después del despliegue.

¹⁸

Fase de staging obligatorio. Sobre un servidor con la misma configuración que producción ejecutar como mínimo:

```
# Integridad
sha256sum ARTEFACTO_FINAL.zip
unzip -t ARTEFACTO_FINAL.zip
```


Apache/configuración

```
apachectl configtest
```

Ejemplos de prueba HTTP

```
curl -I http://rentalscooterbarcelona.com/  
curl -I https://www.rentalscooterbarcelona.com/  
curl -I https://rentalscooterbarcelona.com/  
curl -I https://rentalscooterbarcelona.com/robots.txt  
curl -I https://rentalscooterbarcelona.com/sitemap.xml  
curl -I https://rentalscooterbarcelona.com/api/hours.php
```

Además de la matriz de 200 URLs y todas las redirecciones legacy, en staging deben verificarse CSP en consola, formularios/WhatsApp, mapas, menú de idioma, navegación móvil, 404/410, sitemap, endpoint de horarios, Lighthouse y un escaneo AV/YARA del artefacto final.

Checklist previo a subir

Control	Estado actual
Hash del ZIP final registrado	⚠ Hash disponible, pero del ZIP 2026-09-15(5)
Nombre/versión coincidente con el artefacto autorizado	✗
<code>unzip -t</code> sin errores	✓
200 HTML / 20 grupos / 10 idiomas	✓
Canonical 200/200	✓
Hreflang recíproco 200/200	✓
Sitemap cubre 200 canonicals	✓
JSON/XML válidos	✓
Referencias internas rotas	✓ 0 detectadas
Dimensiones HTML ↔ imágenes correctas	✗ 398 ocurrencias
Teléfono/email coherentes	✓
No oferta e-scooters/e-bikes	✓ en corpus revisado
Política 30/70 confirmada/publicada	⚠
Depósito 250 € confirmado/publicado	⚠
Radio 25 km confirmado/publicado	⚠
Conteo de reseñas actualizado	⚠ 226 ZIP frente a 222 observado en producción
Maps API key restringida en Cloud	⚠ no verificable desde ZIP

Control	Estado actual
SQLi/command injection/deserialización insegura demostradas	✓ ninguna
Secretos privados demostrados	✓ ninguno
CSP presente	✓
CSP endurecida sin <code>unsafe-inline</code>	+ mejora, no bloqueo inmediato
AV/YARA del ZIP final	⚠ no realizado en este entorno
CVE/SBOM determinista	⚠ no hay dependencias versionadas suficientes
Redirects Apache comprobados en runtime	⚠ pendiente staging
Cabeceras reales comprobadas en runtime	⚠ pendiente staging
Lighthouse/CWV real	⚠ pendiente staging
IndexNow	+ opcional
Datos AI factuales y sincronizados	⚠ recomendable revisión

Comandos principales utilizados en la fase forense

```

sha256sum "RSB_WEB_REPO_FINAL_CORREGIDO_REAUDITADO_2026-09-15(5).zip"
sha512sum "RSB_WEB_REPO_FINAL_CORREGIDO_REAUDITADO_2026-09-15(5).zip"
md5sum "RSB_WEB_REPO_FINAL_CORREGIDO_REAUDITADO_2026-09-15(5).zip"

unzip -t "RSB_WEB_REPO_FINAL_CORREGIDO_REAUDITADO_2026-09-15(5).zip"
unzip -q "RSB_WEB_REPO_FINAL_CORREGIDO_REAUDITADO_2026-09-15(5).zip" -d
rsb_audit_extract

find rsb_audit_extract -type f
file --mime-type ...
rg ...

```

A partir de la extracción se efectuaron mediante Python los cruces de rutas, hashes de archivos, parseo HTML/XML/JSON, JSON-LD, hreflang/canonical, enlaces, anchors, `src/srcset`, dimensiones intrínsecas, permisos y patrones de seguridad. **No se modificó el contenido del ZIP.**

Inventarios y trazabilidad

Anexo	Contenido
inventory.csv	Los 317 archivos , path, tipo, bytes, timestamp, CRC32, SHA-256 y modo
html_audit.csv	Auditoría estructurada de los 200 HTML
image_inventory.csv	Imágenes y dimensiones intrínsecas

Anexo	Contenido
issues_raw.csv	Evidencias brutas; filtrar <code>IMG_DIM_RATIO_MISMATCH</code> para las 398 incidencias
sitemap_inventory.csv	URLs, alternates y datos de sitemaps
jsonld_entities.csv	Entidades y <code>@id</code> extraídos de JSON-LD
security_scan.csv	Resultados de búsqueda estática de seguridad

Limitaciones que no deben ocultarse. No se auditó dinámicamente Apache/PHP en el servidor de destino; no se midieron CWV reales; no se accedió a Google Cloud para comprobar restricciones de la API key; no se consultó la consola de Google Business para conocer el número real de reseñas; no se dispuso de ClamAV/YARA ni de un SBOM versionado capaz de atribuir CVEs. Y, sobre todo, **no se tuvo acceso al fichero exacto** `RSB_WEB_SERVIDOR_TODOS_CAMBIOS_ACTUALIZADOS_2026-09-13.zip` **solicitado originalmente.**

La revisión estática del paquete disponible es, pese a ello, sustancialmente positiva: 200/200 páginas están presentes; el multilingüe, canonical, hreflang, sitemap y grafo interno no muestran las roturas masivas que serían típicas de un paquete incompleto; JSON-LD/XML/JSON son parseables; no se ha encontrado una vulnerabilidad de inyección demostrable ni secretos privados. El problema técnico objetivo que sí queda es amplio: **398 declaraciones de dimensiones de imagen incorrectas en 198 de 200 HTML**. Además, existen controles de release que no deben quedar sin cerrar, en particular identidad del artefacto y restricciones de la API key.

No recomendaría sustituir todavía la producción con el paquete tal como se ha podido auditar. El criterio para cambiar el dictamen es concreto: conciliar el ZIP/hash final, llevar a cero los 398 errores de relación de aspecto, validar los datos empresariales pendientes, comprobar la key de Maps y pasar el mismo artefacto por staging/runtime y malware scan sin regresiones.

NO APTO TODAVÍA

- 1 <https://web.dev/articles/optimize-cls>
<https://web.dev/articles/optimize-cls>
- 2 <https://developers.google.com/maps/api-security-best-practices>
<https://developers.google.com/maps/api-security-best-practices>
- 3 13 <https://top10.owasp.org/2025/cs/>
<https://top10.owasp.org/2025/cs/>
- 4 <https://rentalscooterbarcelona.com/>
<https://rentalscooterbarcelona.com/>
- 5 <https://developers.google.com/search/blog/2023/06/sitemaps-lastmod-ping>
<https://developers.google.com/search/blog/2023/06/sitemaps-lastmod-ping>
- 6 <https://developers.google.com/search/docs/appearance/structured-data/sd-policies>
<https://developers.google.com/search/docs/appearance/structured-data/sd-policies>
- 7 <https://developers.google.com/search/docs/appearance/ai-features>
<https://developers.google.com/search/docs/appearance/ai-features>

- 8 <https://developers.google.com/search/docs/advanced/crawling/managing-multi-regional-sites>
<https://developers.google.com/search/docs/advanced/crawling/managing-multi-regional-sites>
- 9 14 <https://developers.google.com/search/docs/crawling-indexing/canonicalization>
<https://developers.google.com/search/docs/crawling-indexing/canonicalization>
- 10 <https://developers.google.com/search/docs/appearance/structured-data/review-snippet?authuser=77>
<https://developers.google.com/search/docs/appearance/structured-data/review-snippet?authuser=77>
- 11 <https://developers.google.com/search/updates>
<https://developers.google.com/search/updates>
- 12 <https://developers.google.com/search/docs/appearance/google-images>
<https://developers.google.com/search/docs/appearance/google-images>
- 15 18 <https://www.bing.com/webmasters/help/bing-webmaster-guidelines-30fba23a>
<https://www.bing.com/webmasters/help/bing-webmaster-guidelines-30fba23a>
- 16 <https://www4.bing.com/webmasters/help/url-submission-62f2860b>
<https://www4.bing.com/webmasters/help/url-submission-62f2860b>
- 17 <https://help.openai.com/es-419/articles/20001243-advertiser-guidance-for-allowing-openai-web-crawlers>
<https://help.openai.com/es-419/articles/20001243-advertiser-guidance-for-allowing-openai-web-crawlers>